Update **confidential** designator here

Advanced Container Security

Images, Runtime, Supply Chain, and Platform Hardening

Red Hat

Agenda

- Why container security is different
- Image and registry security
- Supply chain and provenance
- Runtime and workload hardening
- Network and secrets
- Detection and compliance
- Summary

Why It Matters

Containers and Risk

Attack surface

- Containers share the host kernel—isolation is logical, not physical
- Images bundle dependencies; vulnerabilities propagate with every deploy
- Ephemeral workloads complicate forensics without good logging
- Supply chain attacks target registries, CI, and base images
- Defense requires layers: build, ship, run, monitor

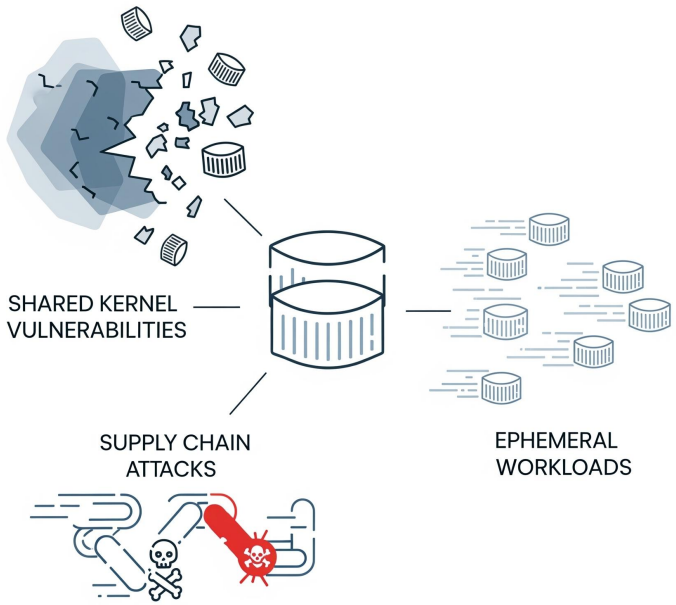

Image and Registry Security

Update **confidential** designator here

Secure Images

- Minimal base images; remove shells and package managers where possible
- Scan images in CI/CD for CVEs (fail or warn on policy)
- Pin digests, not only tags, for immutable references
- Private registries with authentication and RBAC
- Sign images (cosign/sigstore) and verify before deploy

Red Hat

Update **confidential** designator here

Registry Operations

- Replication and air-gapped mirrors for disconnected environments
- Garbage collection and retention policies
- Vulnerability scanning at rest and on admission
- Prohibit pulling from untrusted public registries in production
- Audit who pushed which image and when

Red Hat

Supply Chain

Update **confidential** designator here

Software Supply Chain Security

- SBOM (Software Bill of Materials) for transparency of components
- SLSA-style provenance: who built what, from which source commit
- Signed commits, signed builds, signed artifacts
- Protect CI/CD secrets and separate dev from prod pipelines
- Policy at deploy time: only allow approved signers and bases

Red Hat

Runtime Hardening

Pod and Container Hardening

- Run as non-root user and read-only root filesystem where possible
- Drop Linux capabilities; use default restricted profile (PSS)
- seccomp and AppArmor/SELinux profiles per workload
- Resource limits to reduce noisy-neighbor and DoS impact
- Avoid privileged containers except under strict review

Update **confidential** designator here

Runtime Monitoring

- Behavioral tools: Falco, eBPF-based monitors, vendor CNAPP solutions
- Alert on unexpected syscalls, shell in production, or binary launches
- Correlate with Kubernetes audit logs and admission decisions
- Integrate findings with SIEM for incident response
- Balance noise vs. coverage with tuned rules

Red Hat

Network and Secrets

Update **confidential** designator here

Network Security

- Default deny with NetworkPolicy; allow only required paths
- Egress controls for external calls and DNS filtering
- Service mesh mTLS for service-to-service encryption (where used)
- Ingress hardening: TLS, WAF, rate limits at edge
- Namespace isolation as a security boundary

Red Hat

Secrets Management

- Never bake secrets into images; use Kubernetes Secrets or external vaults
- Encrypt secrets at rest; rotate regularly
- Short-lived tokens and workload identity where possible
- Restrict RBAC who can read secrets in a namespace
- Audit secret access and use sealed secrets or operators for GitOps

Compliance and Admission

Update **confidential** designator here

Policy and Admission Control

- OPA/Gatekeeper or Kyverno: validate manifests against policies
- Block privileged pods, latest tags, or missing resource limits
- Image signature verification at admission
- Compliance frameworks mapped to cluster configuration (CIS, PCI)
- Continuous compliance scanning of running clusters

Red Hat

Update **confidential** designator here

Summary

- Layer defenses: secure images, trusted supply chain, hardened runtime
- Least privilege for processes, networks, and identities
- Automate scanning and policy; fix in CI before production
- Monitor behavior and audit API access for detection
- Align with standards and test incident playbooks regularly

Red Hat

Thank You

Questions? See Kubernetes hardening guides and OpenShift security documentation.

linkedin.com/company/red-hat

youtube.com/user/RedHatVideos

facebook.com/redhatinc

twitter.com/RedHat

Red Hat